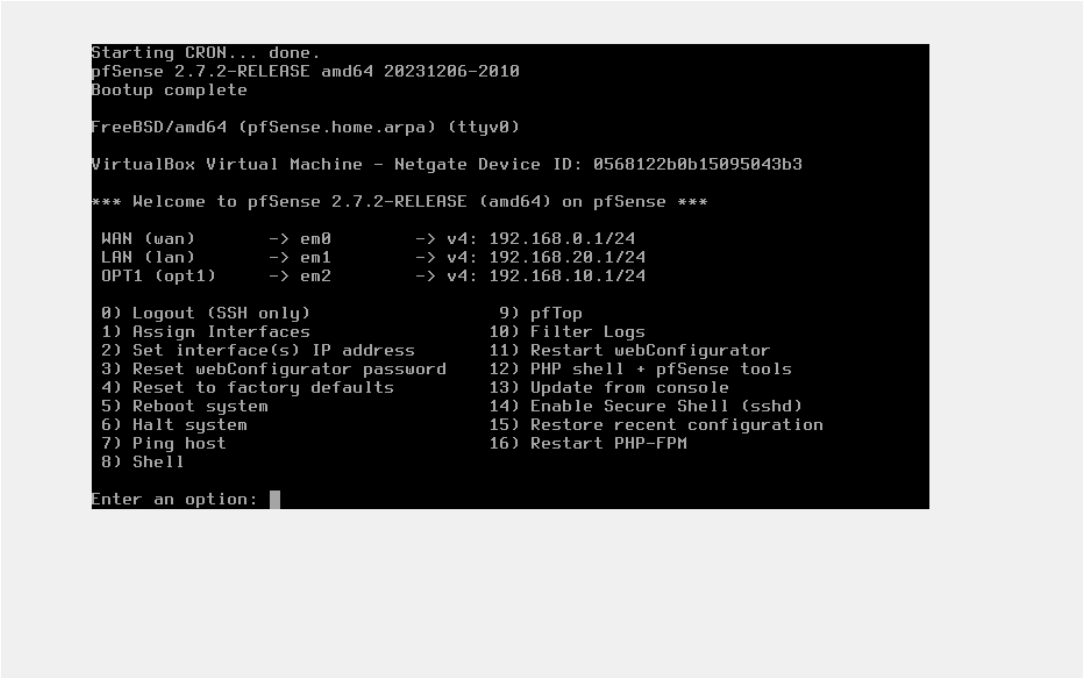
Report Tecnico: Configurazione Firewall/ pfSense e Protezione DVWA

Introduzione

In questo esercizio è stato utilizzato il firewall pfSense per configurare una regola mirata a inibire l'accesso alla piattaforma DVWA (ospitata su Metasploitable ovvero la macchina target) da parte di Kali Linux (la macchina attaccante)
Un requisito fondamentale dell'esercitazione è stata la segmentazione della rete: le macchine Kali e Metasploitable sono state attestate su reti differenti.
Il progetto si è focalizzato sulla capacità di separare il traffico tra un potenziale attaccante e un target sensibile, bloccando ogni comunicazione non autorizzata a livello di rete.

Configurazione Manuale delle Interfacce su pfSense



La configurazione iniziale del firewall è stata eseguita tramite la console testuale di pfSense, seguendo tre passaggi chiave per preparare l'infrastruttura:

1. **Assign Interfaces (Opzione 1)**: Identificazione e assegnazione fisica delle schede di rete (em0,em1, em2)
2. **Set Interface IP Address (Opzione 2)**: Assegnazione manuale degli indirizzi IP statici ai gateway delle due reti: `192.168.20.1` per la LAN e `192.168.10.1` per la OPT1.

3. **Disabilitazione DHCP**: In questa fase è stato volutamente disabilitato il servizio DHCP su entrambe le interfacce per garantire un controllo statico totale e forzare una configurazione manuale dei nodi, simulando un ambiente di rete blindato.

Setup dei Sistemi Operativi e Instradamento (Routing)

Poiché il servizio di assegnazione automatica è stato rimosso, la connettività di rete è stata stabilita agendo manualmente sui parametri interni di Kali e Metasploitable. In questa fase è emerso un problema di comunicazione (Packet Loss) risolto attraverso la configurazione dei **Gateway**.

- **Kali Linux**: Configurazione manuale dell'indirizzo **192.168.20.10**.
- **Metasploitable**: Impostazione statica dell'indirizzo **192.168.10.20**.

Configurazione del Routing e dei Gateway

Nonostante la corretta assegnazione degli indirizzi IP, le macchine non comunicavano poiché appartenevano a sottoreti diverse. Per stabilire la connessione attraverso il firewall, è stato necessario configurare i **Gateway Predefiniti**:

- **Su Kali Linux**: `sudo ip route add default via 192.168.20.1 dev eth0`
- **Su Metasploitable**: `sudo route add default gw 192.168.10.1`

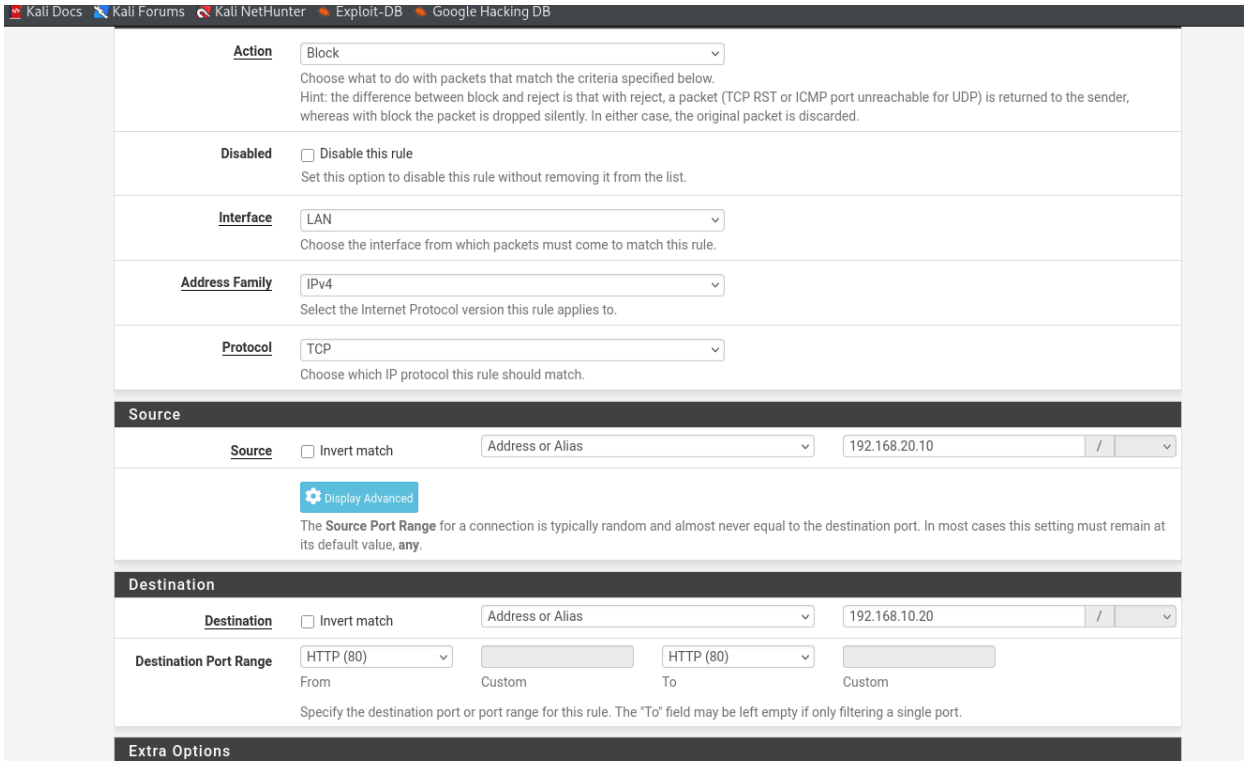
```
┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 192.168.20.10 netmask 255.255.255.0 up
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 down

┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 192.168.20.10 netmask 255.255.255.0 up

┌──(kali㉿kali)-[~]
└─$ sudo ip route add default via 192.168.20.1 dev eth0


┌──(kali㉿kali)-[~]
└─$ ping 192.168.20.10
PING 192.168.20.10 (192.168.20.10) 56(84) bytes of data.
64 bytes from 192.168.20.10: icmp_seq=1 ttl=64 time=0.023 ms
64 bytes from 192.168.20.10: icmp_seq=2 ttl=64 time=0.048 ms
64 bytes from 192.168.20.10: icmp_seq=3 ttl=64 time=0.072 ms
c64 bytes from 192.168.20.10: icmp_seq=4 ttl=64 time=0.028 ms
64 bytes from 192.168.20.10: icmp_seq=5 ttl=64 time=0.074 ms
^C
--- 192.168.20.10 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4095ms
rtt min/avg/max/mdev = 0.023/0.049/0.074/0.021 ms

┌──(kali㉿kali)-[~]
└─$ ping 192.168.10.20
PING 192.168.10.20 (192.168.10.20) 56(84) bytes of data.
64 bytes from 192.168.10.20: icmp_seq=1 ttl=63 time=3.42 ms
64 bytes from 192.168.10.20: icmp_seq=2 ttl=63 time=1.26 ms
64 bytes from 192.168.10.20: icmp_seq=3 ttl=63 time=1.33 ms
64 bytes from 192.168.10.20: icmp_seq=4 ttl=63 time=0.985 ms
64 bytes from 192.168.10.20: icmp_seq=5 ttl=63 time=1.29 ms
64 bytes from 192.168.10.20: icmp_seq=6 ttl=63 time=1.83 ms
64 bytes from 192.168.10.20: icmp_seq=7 ttl=63 time=2.37 ms
^C
--- 192.168.10.20 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 6005ms
rtt min/avg/max/mdev = 0.985/1.783/3.423/0.792 ms

┌──(kali㉿kali)-[~]
└─$
```

```
msfadmin@metasploitable:~$ ping 192.168.20.10
PING 192.168.20.10 (192.168.20.10) 56(84) bytes of data.
64 bytes from 192.168.20.10: icmp_seq=1 ttl=63 time=4.06 ms
64 bytes from 192.168.20.10: icmp_seq=2 ttl=63 time=2.06 ms
64 bytes from 192.168.20.10: icmp_seq=3 ttl=63 time=2.03 ms
64 bytes from 192.168.20.10: icmp_seq=4 ttl=63 time=1.02 ms
64 bytes from 192.168.20.10: icmp_seq=5 ttl=63 time=2.62 ms

--- 192.168.20.10 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4002ms
rtt min/avg/max/mdev = 1.027/2.363/4.061/0.993 ms
msfadmin@metasploitable:~$ sudo route add default gw 192.168.10.1
SIOCADDRT: File exists
msfadmin@metasploitable:~$ ping 192.168.20.1
PING 192.168.20.1 (192.168.20.1) 56(84) bytes of data.
64 bytes from 192.168.20.1: icmp_seq=1 ttl=64 time=0.328 ms
64 bytes from 192.168.20.1: icmp_seq=2 ttl=64 time=1.25 ms
64 bytes from 192.168.20.1: icmp_seq=3 ttl=64 time=0.418 ms
64 bytes from 192.168.20.1: icmp_seq=4 ttl=64 time=0.520 ms
64 bytes from 192.168.20.1: icmp_seq=5 ttl=64 time=1.26 ms

--- 192.168.20.1 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4001ms
rtt min/avg/max/mdev = 0.328/0.757/1.266/0.417 ms
msfadmin@metasploitable:~$
```

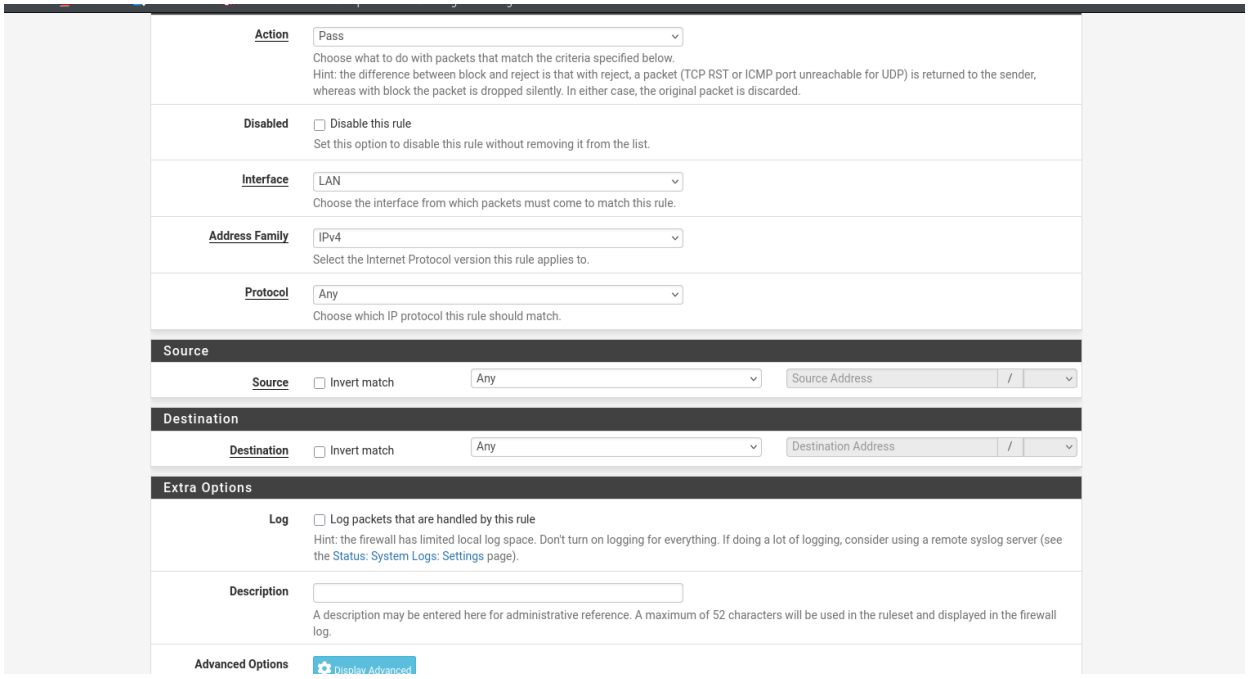
Configurazione delle Regole su pfSense

In seguito, abbiamo operato sull'interfaccia web di pfSense tramite il browser di Kali Linux per definire le politiche di sicurezza.
Le regole sono state create nella sezione **Firewall > Rules > LAN**

- **Regola di Blocco (HTTP)**: Abbiamo impostato una regola di tipo `Block` per il protocollo **TCP** sulla porta **80**



- **Regola di Permesso (Any)**:Abbiamo inserito una regola di tipo Pass per permettere tutto il resto del traffico .

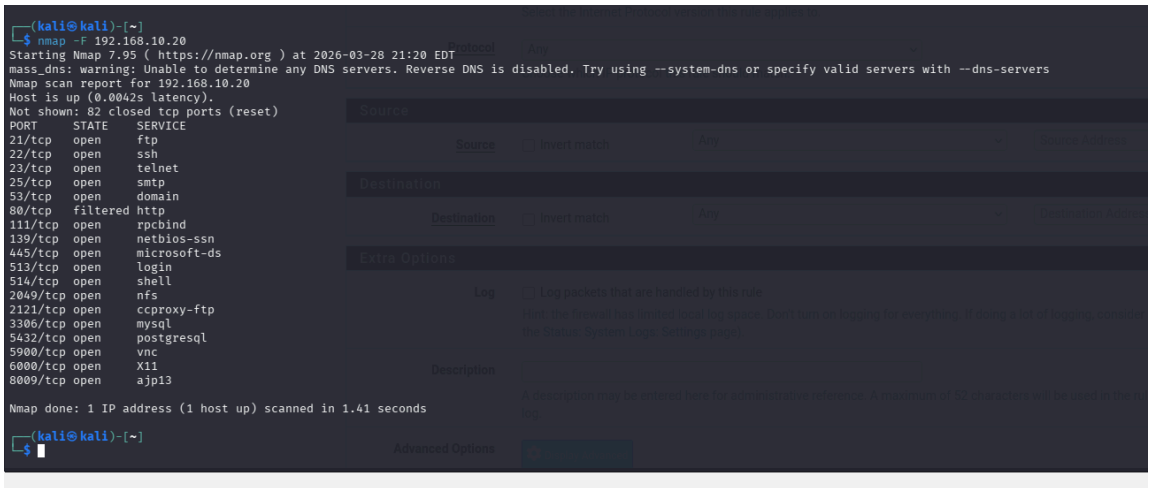


Analisi e Risultati dello Scan (Nmap)

Per verificare l'efficacia della configurazione, abbiamo eseguito una scansione delle porte da Kali utilizzando il comando: ***nmap -F 192.168.10.20***

L'effetto ottenuto:

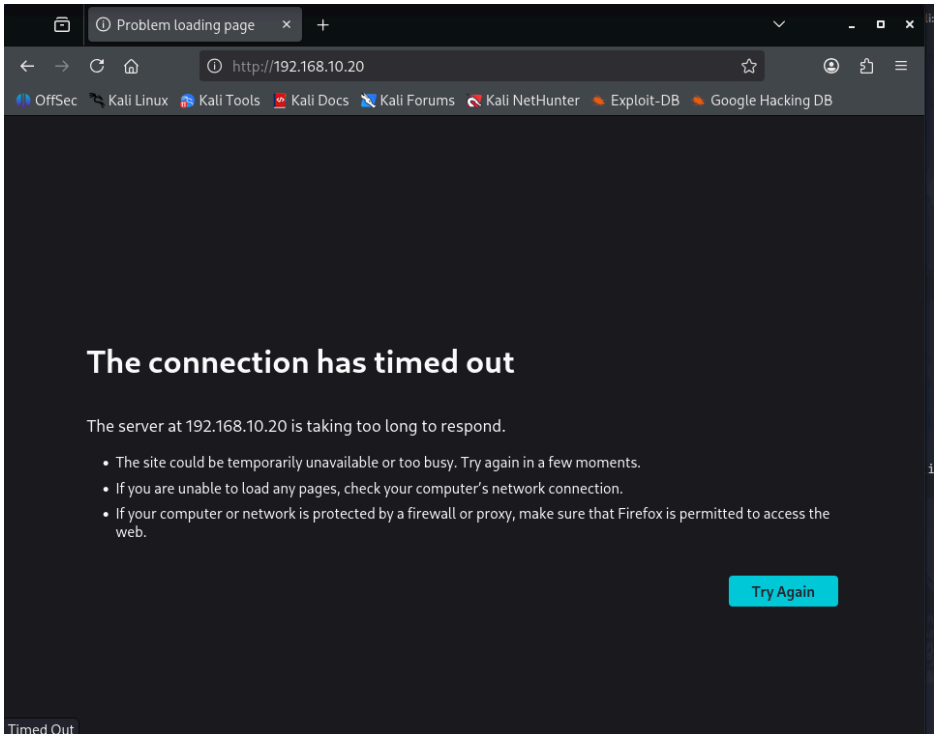
1. **Porta 80/tcp**: Risulta in stato ***filtered***.
2. **Altre Porte**: Risultano in stato ***open***.



Verifica Finale tramite Browser

Il test definitivo è stato effettuato tentando di aprire l'indirizzo `http://192.168.10.20` nel browser di Kali.

- **Risultato**: La pagina è andata in **Timeout**.



Considerazioni Finali e Risultati

L'esercitazione ha confermato l'efficacia di pfSense nella protezione di asset critici.

- È stato possibile isolare servizi specifici (HTTP) senza interrompere l'operatività degli altri protocolli di rete.
- Lo stato **"filtered"** rilevato da Nmap certifica che il firewall non si limita a rifiutare la connessione, ma scarta attivamente i pacchetti, rendendo il target invisibile a tentativi di scansione esterna.

L'esperienza evidenzia come una corretta configurazione del firewall sia vitale per proteggere asset critici (come la DVWA) all'interno di un'infrastruttura professionale o di laboratorio, limitando preventivamente il raggio d'azione di potenziali utenti malintenzionati ed eventuali attacchi.